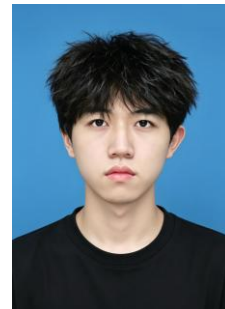


郭哲宇

本科 211 全日制统招, 27 年应届生

性别: 男 | 年龄: 21 | 电话: 13033418015 | 邮箱: 1974636592@qq.com



自我评价

具备完整网络安全理论基础, 深耕 Web 漏洞研究与利用链构造, 具备企业级安全运维、应急响应与防护体系建设经验。系统掌握 RCE、SQL 注入、反序列化、文件上传、SSTI、SSRF、XXE、业务逻辑等核心漏洞原理与绕过姿势; 多次参与 MOECTF、SHCTF、西湖论剑、看雪 CTF 等行业赛事, 具备靶场刷题、漏洞复现与独立撰写技术 WP 能力。同时拥有多场政企攻防演练、重保行动的完整实战经验, 熟悉 NGSOC / WAF / EDR / 蜜罐 / 天眼等企业安全设备运维, 精通流量研判、恶意样本分析、攻击全链路溯源与应急响应全流程处置。善于利用 AI 辅助代码审计与漏洞分析, 具备持续自主学习与技术复盘能力。

实习经历

山西时尖科技有限公司

安全服务工程师

2023.09 — 2024.06

- 对接政务、高校共 12 家政企客户, 使用 AWVS 等开展授权渗透 20 余次, 挖掘 Redis 未授权、Nacos 弱口令 / CVE-2021-29441、SQL 注入、Swagger 未授权、Memcached 信息泄露等中高危漏洞 60 余个, 输出落地修复方案并全程跟进复测闭环
- 运维防火墙、WAF 安全设备, 7×24 小时监控 445/11211/8848 等高危端口流量, 持续拦截暴力破解、命令执行、挖矿外联各类攻击; 输出多套等保 2.0 合规加固、边界 ACL 优化方案, 常态化梳理暴露资产、收紧 Web 访问权限
- 成果: 客户服务器入侵、横向渗透事件同比下降 65%, 获得多家政企书面服务认可

武汉国家网络安全人才与创新基地 (NCC)

网络安全实训生

2026.07 — 至今

项目经历

上海某大学教育行业攻防演练

研判应急溯源工程师

2025.07

- 运维 NGSOC、天眼、WAF、EDR、蜜罐整套防护体系, 实时监控 8848/11211/3389/445 等端口流量, 识别 Nacos 爆破、Memcached 敏感查询、RCE、SMB 横向移动、RDP 暴力破解攻击载荷
- 全程 7×24 小时值守应急响应, 抓取原始流量上机排查, 完成 ELF 木马静态 / 动态分析、后门查杀; 全链路溯源攻击者 IP 段, 对内网跳板开展反渗透, 清理持久化后门、计划任务残留入侵通道
- 成果: 院校防守排名创历年新高; 阻断 4 轮跨网段 SMB 横向渗透, 查杀 3 组 Webshell 后门, 为 9 套核心业务输出鉴权、版本升级加固方案, 完整溯源多批次攻击并输出复盘报告

武汉某市数据局电子政务攻防演练

现场防守组长

2025.07 — 2025.09

- 统筹现场防守班组, 依托云防火墙、流量探针、NGSOC 搭建多层防护, 持续监控 8080/8848/6379/11211/3306 端口, 识别 Redis 未授权、Nacos 漏洞、HttpFileServer 木马下载、SQL 注入等异常流量, 实时下发 IP 封禁策略
- 对红方攻击集群画像追踪, 梳理肉鸡、跳板、公网服务器三级链路, 批量封禁攻击 IP 段; 深度逆向 amd64 Linux 木马, 通过 Whois、微步情报溯源境外攻击者并完成反向渗透取证
- 对接政企双方同步态势, 每日汇总全网攻击数据, 编制值守日报、行业风险通告, 统一下级单位防御标准
- 成果: 演练全程零失分, 批量封禁上百组攻击 IP 池, 溯源渗透攻陷红方服务器, 斩获全市防守第一名, 获书面表彰并锁定次年驻场项目名额

某金融厂商内部众测项目

渗透测试员

2024.07 — 2024.09

- 遵循金融安全测试规范, 完成资产测绘、端口扫描、目录爆破、业务逻辑全流程审计, 复现 SQL 联合注入、垂直 / 水平越权、文件上传绕过、明文敏感传输漏洞, 构造载荷评估资金、用户信息泄露风险
- 分级标注漏洞风险、攻击路径与资产影响, 输出金融专属修复方案; 配合研发复测漏洞, 优化 WAF 正则、接口访问风控策略
- 成果: 累计发现中危漏洞 2 个、低危漏洞 2 个 (含批量导出客户数据越权漏洞) 全部整改闭环; 标准化测试 Checklist, 同类系统检测周期缩短 30%, 规避资金篡改、隐私批量泄露风险

其他项目经历

山西某运营商重保行动 (封禁恶意 IP 2000+ 个, 拦截攻击 30 万+次) | 遂宁教育局安全值守 (拦截 Web 攻击 1.2 万余次) | 大学校园网规划设计 (三层高可用方案, 获老师认可留存示范) | SpringBoot 申报系统 AI 开发 (独立完成前后端, RBAC 分级权限体系) | XSS 漏洞之 Cookie 获取与会话劫持 (BeEF 框架, 全攻击链路复现)

漏洞研究笔记体系 个人知识库 2022 — 至今

- 覆盖漏洞类型: RCE (命令执行 / 代码执行)、SQL 注入 (联合 / 盲注 / 报错)、反序列化 (PHP / Java)、文件上传 (解析漏洞 / 黑名单绕过)、SSTI 模板注入、SSRF、XXE、XSS / CSRF、业务逻辑漏洞、并发竞争条件、JWT 安全、LLM 安全等
- 核心产出: 系统总结 CTF 场景下各类过滤绕过姿势, 包括 RCE 通配符绕过 (fla*.ph*)、同义函数替换 (shell exec 替 system)、参数逃逸 (\$ GET[1] 二次传参)、伪协议配合 (data:/// php://filter)、空格绕过 (\$IFS / {cat,flag})、命令拼接符 (| / & / || / &&) 等; 整理 PHP / Java / Python 危险函数清单与漏洞触发条件; 构建漏洞发现 → 利用 → 绕过的完整思维框架
- 因系统故障丢失早期部分 CTF 比赛 WP, 已恢复并持续更新核心漏洞原理与绕过技术文档

校园经历

校创新实验室

网络安全部 - 组长

2022.09 — 2027.07

- 大一基础夯实阶段: 系统学习 TCP/IP 网络架构、OSI 七层模型、Web 安全全品类漏洞原理、渗透测试基础工具; 实验室实行标准化培养机制, 坚持每日提交学习复盘日志, 每半年开展专业技能考核并执行末位淘汰, 全程稳定留存
- 大二实战竞赛阶段: 深耕 CTF 攻防赛道, 先后参与 MOECTF、SHCTF、西湖论剑、看雪 CTF 等多场行业赛事; 持续在各类公开靶场刷题复现漏洞, 沉淀攻击思路与绕过技巧, 独立撰写漏洞复现、CTF 解题 WP 并发布个人技术博客
- 大三高阶进阶阶段: 自主深入学习应急响应全流程处置、JS 前端逆向、Windows/Linux 双系统权限提升、数据库提权等高阶安全技术, 完整覆盖攻防演练、内网渗透核心技能栈

• 留任新生带教：连续两年留任实验室，担任组长，定制零基础网安学习路线，定期开展内部靶场对抗、漏洞复盘分享会，系统性带教大一新生掌握网络基础、Web 漏洞挖掘、渗透工具实操

校军乐团

部长

2022.09 — 2027.07

• 统筹乐团日常排练、校内演出安排，锻炼团队统筹协调、人员管理能力。

专业技能

漏洞研究与利用：

- RCE：精通 PHP 代码执行 (eval / assert / preg_replace / create_function / call_user_func 等) 与命令执行 (system / exec / shell_exec / popen / proc_open 等) 函数利用；掌握 CTF 场景下多种绕过姿势：通配符绕过 (fla.ph)、同义函数替换 (shell_exec 替 system)、参数逃逸 (\$ GET[1] 二次传参)、伪协议配合 (data:/// php://filter)、空格绕过 (\$IFS / {cat,flag} / %09)、命令拼接符 (| / & / || / && / %0a) 等
- SQL 注入：精通 union 联合注入、布尔盲注、时间盲注、报错注入；掌握 information_schema 有据查询脱库；熟悉多种 WAF 绕过与过滤绕过技巧
- 反序列化：掌握 PHP 反序列化链构造 (魔术方法触发链：wakeup → destruct → __toString)、Java 反序列化识别 (r00AB / aced 特征)、字符串逃逸技术
- 文件上传：精通解析漏洞 (Apache .php.rar、Nginx 1.jpg/1.php、IIS 1.asp;1.jpg)、黑名单绕过 (.htaccess、特殊解析后缀 .phtml / .php5、大小写绕过)、白名单绕过思路
- SSTI 模板注入：掌握多语言模板引擎 (Jinja2 / Twig / Smarty 等) 识别与利用链构造，熟悉原生对象逃逸至 os / rce 的 Payload 构造
- 其他漏洞：精通 XSS (存储 / 反射 / DOM)、SSRF (内网探测 / 协议走私)、XXE (实体注入 / 文件读取)、业务逻辑漏洞 (越权 / 支付 / 密码找回)、并发竞争条件、JWT / OAuth 认证绕过

安全运维与防护体系建设：

- 企业安全设备：具备天眼 / EDR / WAF / 蜜罐 / NGSOC 等企业安全设备运维与策略调优经验
- 应急响应：精通 7×24 值守、流量研判、恶意样本静态 / 动态分析、后门查杀、攻击全链路溯源、威胁情报关联分析
- 防护体系：熟悉多层纵深防御架构搭建 (云防火墙 + 流量探针 + NGSOC 联动)，实时高危端口监控与 IP 封禁策略下发
- 合规与加固：熟悉等保 2.0 合规要求，具备边界 ACL 优化、暴露资产梳理、Web 访问权限收紧、鉴权与版本升级加固方案输出能力
- 日志分析：掌握原始流量抓取与分析、攻击载荷识别、攻击集群，画像追踪、肉鸡 - 跳板 - C2 三级链路梳理

渗透测试与代码审计：

- 熟悉黑盒漏洞挖掘流程 (信息搜集 → 资产测绘 → 功能点审计 → Payload 构造 → 利用验证)
- 具备基础白盒代码审计能力，熟悉常见漏洞函数特征与危险代码模式
- 熟练 BurpSuite、Sqlmap、Nmap、蚁剑、冰蝎、Goby、AWVS 等工具及联动使用

开发基础：

- 熟悉 SpringBoot 全栈开发、RBAC 权限体系；熟练 Linux / Windows Server 系统操作与加固；了解 Docker 容器基础

办公：

- Microsoft Office (PPT、Word、Excel) | Typora | Visio，有丰富攻防报告、技术方案输出经验

AI 与前沿安全：

- 善用 AI 辅助代码审计、攻击链路研判、安全文档自动化；掌握 Prompt 工程，具备 LLM 安全研究、AI 赋能安全项目实操经验

荣誉资质

学业：

CISP-2 级证书 (注册信息安全专业人员)
国家计算机等级考试二级
大学英语四级 (CET-4)
校级二等奖学金、三等奖学金 (连续 3 年)
“学业优秀个人”、“文化艺术优秀个人”、“公益服务优秀个人”等各项荣誉称号 (连续 3 年)

竞赛：

第四届“复兴杯”大学生网络安全精英赛荣誉证书
第四届中国大学生智能照明和智能穿戴创新创业大赛三等奖

教育背景

太原理工大学 (211) 软件工程 本科

2022.09 — 2027.07

- 学业成绩：专业前 40%，连续 3 年获校级奖学金
- 核心课程：计算机网络、信息安全技术、操作系统、数据库原理、Web 系统与技术
- 休学一年，全年全职参与多场政企、教育、政务行业护网攻防演练项目，独立负责流量研判、应急溯源、渗透防守、漏洞整改全流程工作